

Secure Software Engineering – 20CYS401

Lab Exercise - 3

Threat Modelling with OWASP Threat Dragon

Learning Objectives:

By the end of this lab, you will be able to:

- Draw a Data Flow Diagram (DFD) to map system components, data flows, and trust boundaries.
- Apply the STRIDE methodology to systematically identify security threats.
- Propose and document technical mitigations for identified architectural flaws.

The Scenario: PayCloud HR System

PayCloud is a cloud-based payroll management system used by corporate clients. It allows standard employees to view their payslips and HR administrators to upload payroll data and issue payments.

The architecture team has provided the following system details:

- **Users:**
 - *Employees* access the system via web browsers over the internet.
 - *HR Admins* access the system via web browsers over the internet.
- **Web Application (Frontend):** A Node.js web server hosted in a public cloud DMZ. It serves the UI, handles user authentication, and routes requests.
- **Payroll API (Backend):** A Python-based API server hosted on a private cloud subnet. It processes business logic, calculates tax deductions, and enforces role-based access controls (RBAC).

- **Relational Database:** A PostgreSQL database in a restricted database subnet. It stores user credentials, salary details, and personal identification numbers.
- **Document Store:** An AWS S3 bucket (Data Store) that holds generated PDF payslips. The API server fetches these and passes them to the Web Application.

Task 1: Scope Definition

Initialize your workspace in OWASP Threat Dragon and define the scope of the assessment.

Requirements:

- Set the model title to **PayCloud Payroll System**.
- Provide a brief description of the system's purpose.
- Set the business criticality to **High**, as the system handles PII and financial data.

Task 2: Architecture Mapping

Translate the text-based architecture into a visual Data Flow Diagram (DFD) within Threat Dragon.

- **Draw the DFD** including all necessary External Entities (Actors), Processes, and Data Stores based on the scenario.
- Map and clearly label all **Data Flows** between the components to show exactly what data is moving (e.g., "HTTPS / Login Credentials" or "Internal API / Fetch PDF").
- Establish **Trust Boundaries** to segment the distinct network zones:

Example:

- *Boundary 1:* Separating the External Actors (Internet) from the Web Application (DMZ).
- *Boundary 2:* Separating the Web Application from the internal Payroll API and Data Stores.

Task 3: STRIDE Threat Identification

Analyze your completed DFD to identify architectural flaws.

- Identify and document a realistic threat for STRIDE (**Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege**)

- Map each threat to the specific component or data flow where it occurs in your diagram. Include a brief description explaining how the attack happens and its impact.

Task 4: Documenting Mitigations

For every threat logged in Task 3, define a corresponding security control to defend the system.

- Document a specific, technical mitigation strategy for each of the six identified threats directly within the threat model.
- Update the status of each threat to reflect whether the mitigation is actively in place or currently proposed.

Final Submission:

1. Your Documentation as pdf [Mention your name and Roll number in the document]
2. PDF Report Generated with OWASP Threat Dragon
3. Project JSON file

References:

1. <https://owasp.org/www-project-threat-modeling/>
2. https://owasp.org/www-community/Threat_Modeling_Process
3. <https://owasp.org/www-project-threat-dragon/>
4. <https://github.com/owasp/threat-dragon>